Análise Dinâmica Básica

Sandboxing

1. O Conceito de Sandbox

A análise dinâmica consiste em executar o malware propositalmente para observar seu comportamento em tempo real. Para isso, é obrigatório o uso de uma **Sandbox** (caixa de areia): um ambiente isolado e controlado que impede que a ameaça infecte a máquina real (host) ou a rede de produção.

2. Requisitos de uma Sandbox Segura

- **Isolamento de Rede:** A VM não deve ter acesso a sistemas sensíveis. Muitas vezes usa-se o modo *Host-Only* ou redes simuladas (como o INetSim).
- **Snapshots (Instantâneos):** É o recurso mais crítico. Permite salvar o estado "limpo" da máquina e reverter para ele instantaneamente após a infecção, garantindo que a próxima análise não seja contaminada.
- **Mecanismo de Transferência:** Uso de pastas compartilhadas ou ISOs para levar o malware até a VM.
    - *Atenção:* Pastas compartilhadas devem ser desmontadas durante a execução para evitar que ransomwares criptografem arquivos do seu computador real.

3. Ferramentas de Virtualização

Ferramenta	Uso	Observação
VirtualBox	Gratuito / Open Source	Suporta snapshots, ideal para laboratórios pessoais.
VMware Workstation	Pago (Profissional)	Alta performance e excelente suporte a snapshots.
VMware Player	Gratuito	**Não recomendado**, pois não possui o recurso de snapshots.
QEMU/KVM	Open Source (Linux)	Usado em larga escala para sandboxes automatizadas (ex: Cuckoo).

Ferramentas de Monitoramento: Process Monitor (ProcMon)

1. O que é o ProcMon?

O ProcMon é um utilitário avançado da suíte **Sysinternals** (Microsoft) que monitora em tempo real as atividades do Sistema de Arquivos, Registro e Processos/Threads. Em análise de malware, ele é essencial para identificar quais arquivos o artefato cria, quais chaves de registro ele modifica para ganhar persistência e se ele tenta se comunicar com a rede.

2. Controles Essenciais

Para não se perder entre os milhares de eventos gerados pelo Windows, o analista deve dominar estes ícones:

- **Capture (Ctrl+E):** Inicia ou interrompe a coleta de dados.
- **Clear (Ctrl+X):** Limpa a tela. Use isso imediatamente antes de executar o malware para reduzir o "ruído" do sistema.
- **Filtro (Ctrl+L):** A alma da ferramenta. Permite focar apenas no processo do malware (ex: `Process Name is malware.exe -> Include`).

3. As 5 Categorias de Eventos

O ProcMon divide os eventos em colunas que podem ser ligadas/desligadas:

1. **Registry (Registro):** Mostra leitura/escrita em chaves de configuração (essencial para ver persistência).
2. **File System (Arquivo):** Mostra criação, leitura e exclusão de arquivos (essencial para ver *payloads* escondidos).
3. **Network (Rede):** Mostra tentativas de conexão (IPs e Portas).
4. **Process/Thread:** Mostra quando o malware cria novos processos (ex: abrindo o `cmd.exe`).
5. **Profiling:** Eventos de desempenho (menos usados em malware).

4. Árvore de Processos (Process Tree)

Acessível pelo ícone de árvore ou `Ctrl+T`, esta visualização é vital para entender a **genealogia do ataque**. Se o malware (`malware.exe`) abrir um processo filho (`powershell.exe`), a árvore mostrará essa relação hierárquica, facilitando a identificação de comportamentos suspeitos de "process spawning".

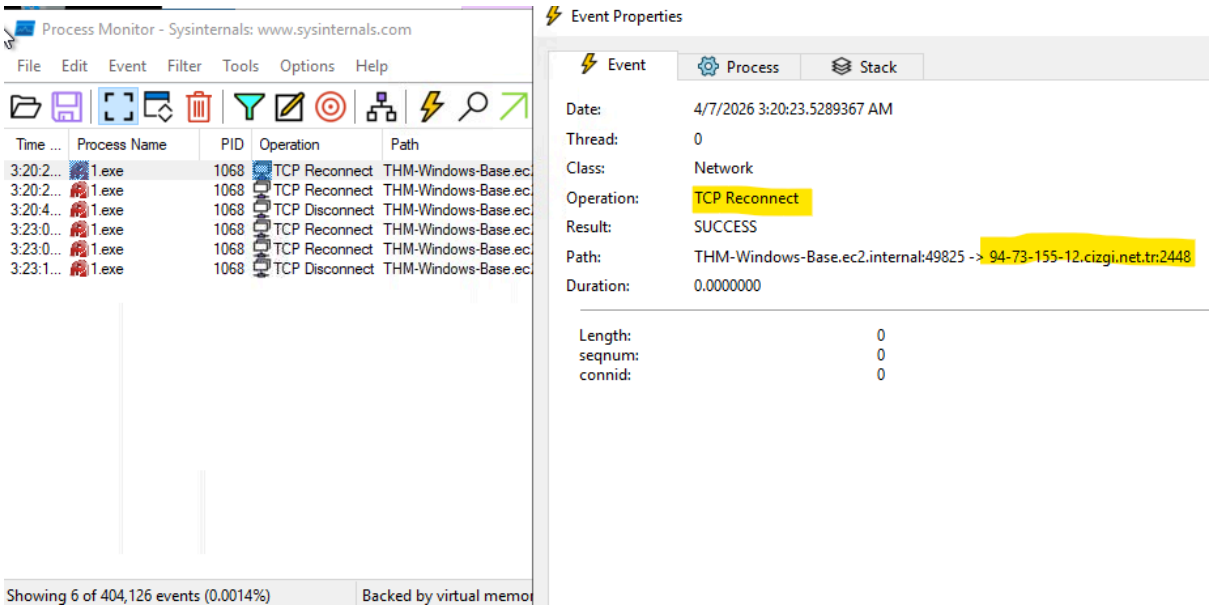
Análise Dinâmica: Monitoramento com ProcMon (Amostra 1.exe)

Nesta etapa, a amostra maliciosa foi executada em um ambiente de *Sandbox* controlado, utilizando o **Process Monitor** para capturar eventos de rede e criação de processos em tempo real.

1. Monitore a amostra \Samples\1.exe usando o ProcMon. Esta amostra faz algumas conexões de rede. Qual é a primeira URL na qual uma conexão de rede é feita?

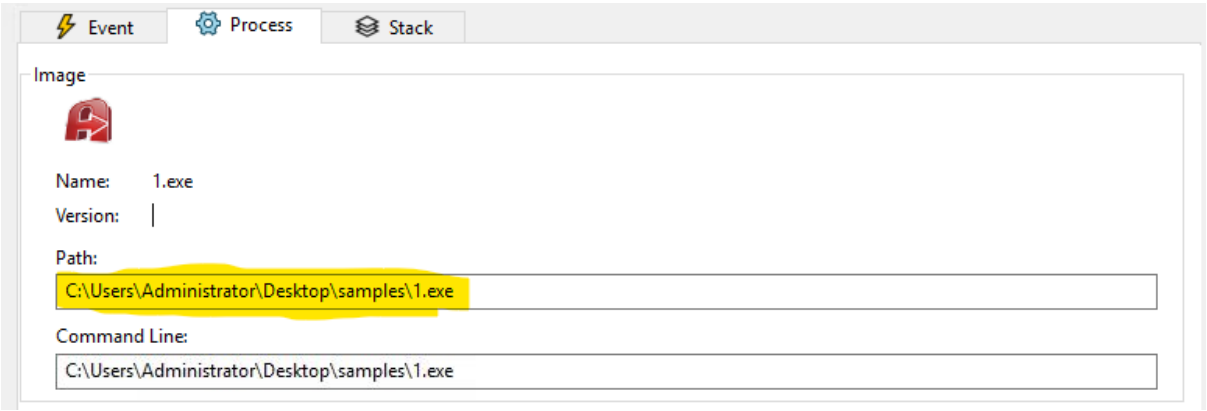
Resposta: `94-73-155-12.cizgi.net.tr:2448`

2. Que operação de rede é realizada no URL mencionado acima?



Resposta: `TCP Reconnect`

3. Qual é o nome e o caminho completo do primeiro processo criado por esta amostra?



Resposta: `C:\Users\Administrator\Desktop\samples\1.exe`

Monitoramento de chamadas de API (API Logging)

A análise de chamadas de API permite identificar o comportamento do malware através das funções que ele solicita ao sistema operacional (ex: criar arquivos, abrir registros, conectar à rede).

1. API Logger

Uma ferramenta de uso rápido que fornece uma visão geral das APIs chamadas por um processo.

- **Funcionamento:** Permite injetar um monitor em um executável novo ou anexar-se a um processo já em execução (via PID).
- **Saída:** Exibe o nome da API e uma mensagem básica com os parâmetros utilizados. É ideal para identificar rapidamente se um malware está tentando, por exemplo, abrir uma chave de registro.

2. API Monitor (x86/x64)

Uma ferramenta avançada que detalha minuciosamente a interação entre o processo e o Windows.

- **Filtros de Grupo:** Permite selecionar categorias específicas, como "Internet", "Graphics" ou "Filesystem", para reduzir o ruído na análise.
- **Captura de Parâmetros (Aba 5):** Diferente do Logger, o Monitor mostra os valores dos parâmetros **antes** e **depois** da chamada da API. Isso é vital para ver, por exemplo, qual dado exato foi escrito em uma chave de registro ou qual URL foi requisitada.
- **Call Stack (Aba 7):** Exibe a pilha de chamadas, permitindo que o analista rastreie qual módulo ou função interna do malware disparou aquela ação específica.
- **Tratamento de Erros:** Exibe o valor de retorno e códigos de erro das APIs, o que ajuda a identificar se o malware falhou em uma tentativa de persistência ou se detectou um ambiente de análise.

Análise de Comportamento e Monitoramento de APIs (Amostra 1.exe)

Após a execução da amostra em ambiente de sandbox, utilizamos o **API Monitor** e o **ProcMon** para identificar as ações do binário no sistema operacional.

1. Qual o nome e o caminho completo do arquivo criado pela amostra no diretório C:?

- **Análise:** O malware tenta se camuflar utilizando um nome de arquivo que mimetiza um componente legítimo do Windows relacionado à hibernação.

- **Resposta:** `C:\myapp.exe`

```
pid: cd8 - 40194e     CreateFileA(C:\Users\Administrator\Desktop\samples\1.exe)
pid: cd8 - 6e3341     CreateFileA(C:\myapp.exe)
pid: cd8 - 6e335f     CreateFileA(C:\Windows\explorer.exe.\)
pid: cd8 - 6e315d     CreateToolhelp32Snapshot(flags:2, pid:0)
pid: cd8 - 766ca4fc     CreateProcessInternalW(, C:\Users\Administrator\Desktop\samples\1.exe, flags=4, hProcess=290)
pid: ac0 - 10005617     CreateToolhelp32Snapshot(flags:2, pid:0)
pid: ac0 - 10005617     CreateToolhelp32Snapshot(flags:2, pid:0)
pid: ac0 - 72ab8f31     CreateMutexA(Local\ZonesCacheCounterMutex) = 0x42c
pid: ac0 - 72ab8f31     CreateMutexA(Local\ZonesLockedCacheCounterMutex) = 0x410
```

2. Qual chamada de API foi usada para fazer a conexão de rede com a URL identificada anteriormente?

- **Análise:** Identificar a API de rede revela qual biblioteca o malware utiliza para se comunicar com o servidor de Comando e Controle (C2).
- **Resposta:** `InternetConnectW`

```
pid: ac0 - 40a126     InternetConnectW(94.73.155.12) = cc0008
```

3. Qual chamada de API é responsável pela diminuição repentina da atividade da amostra durante o monitoramento?

- **Análise:** Esta é uma técnica comum de evasão. O malware entra em estado de dormência para enganar sistemas de análise automática que possuem tempo limite de execução.
- **Resposta:** `Sleep`

pid	msg	Count
135c	77ac9c85 ExitThread()	1
ac0	40a126 InternetConnectW(89.108.71.148) = cc0008	
ac0	40a1a0 HttpOpenRequestW(cc0008, POST, /) = cc000c	
ac0	6cf2d741 bind(48c, port=0)	
ac0	6cf31f9f closesocket(48c)	
ac0	402033 Sleep(20f58)	
135c	40a126 InternetConnectW(221.132.35.56) = cc0008	
135c	40a1a0 HttpOpenRequestW(cc0008, POST, /) = cc000c	
135c	6cf2d741 bind(490, port=0)	
135c	6cf31f9f closesocket(490)	
135c	402033 Sleep(3ff70)	
ac0	77ac9c85 ExitThread()	1

Monitoramento Avançado: Process Explorer

O **Process Explorer** funciona como um Gerenciador de Tarefas "com esteroides", permitindo uma visão profunda dos processos, suas DLLs e handles abertos. Ele é essencial para detectar duas técnicas clássicas de evasão:

1. Detecção de Process Masquerading (Mascaramento)

O malware tenta se passar por um processo legítimo do Windows (ex: um `svchost.exe` falso).

- **Como identificar:** Nas **Propriedades** do processo, aba **Imagem**, utilizamos o botão **Verify**.
- **O Alerta:** Se o processo afirma ser da "Microsoft Corporation", mas o resultado for *"No signature was present in the subject"*, trata-se de um executável não assinado se passando por um binário oficial.

2. Detecção de Process Hollowing (Escavação)

Nesta técnica, o malware usa a "casca" de um processo legítimo, mas substitui o código interno na memória pelo seu payload malicioso.

- **A "Prova do Crime":** O Process Explorer permite comparar as **Strings** do executável em duas instâncias:
    1. **Image:** Strings do arquivo guardado no disco.
    2. **Memory:** Strings do código que está rodando na RAM agora.
- **O Alerta:** Se as strings da memória forem completamente diferentes das strings da imagem em disco, o processo sofreu **Hollowing**. O executável legítimo foi "esvaziado" e preenchido com o código do atacante.

3. Análise de Identificadores (Handles)

Ao ativar o painel inferior (**Lower Pane View**), podemos ver os **Handles**. Se um processo suspeito tem handles abertos para threads ou seções de memória de outros processos (como o `lsass.exe`), isso é um forte indício de **Injeção de Código**.

Para finalizar a sua documentação **Advanced_Static_Analysis**, selecionei as questões que utilizam os recursos mais avançados do **Process Explorer** para desmascarar o malware.

Essas questões são as melhores porque focam em **Mutexes** (usados para o malware não se infectar duas vezes), **Assinaturas Digitais** (mascaramento) e **Integridade de Memória** (hollowing).

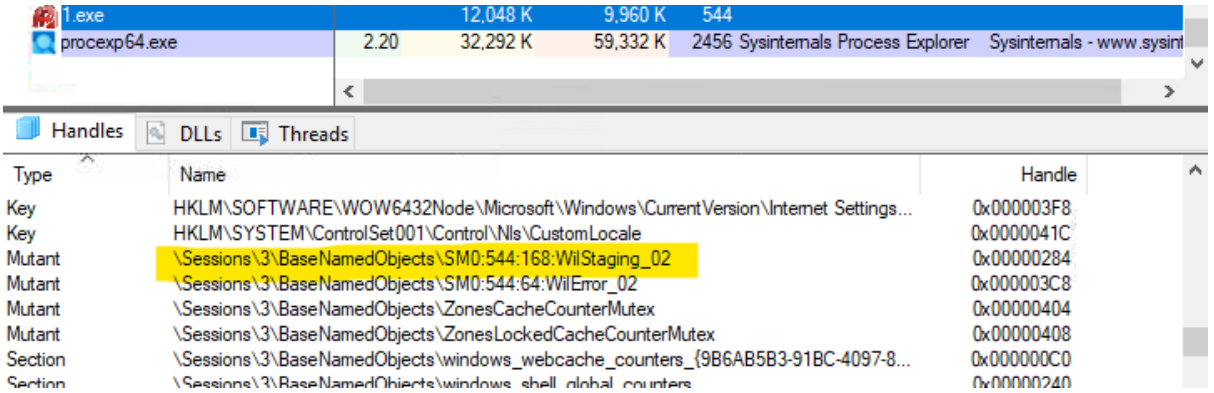
Análise de Processos e Memória: Process Explorer

Nesta etapa, utilizamos o **Process Explorer** para investigar as propriedades internas do processo em execução e identificar técnicas de evasão.

1. Qual é o nome do primeiro Mutex criado pelo exemplo \Desktop\samples\1.exe? (Substituindo números por X)

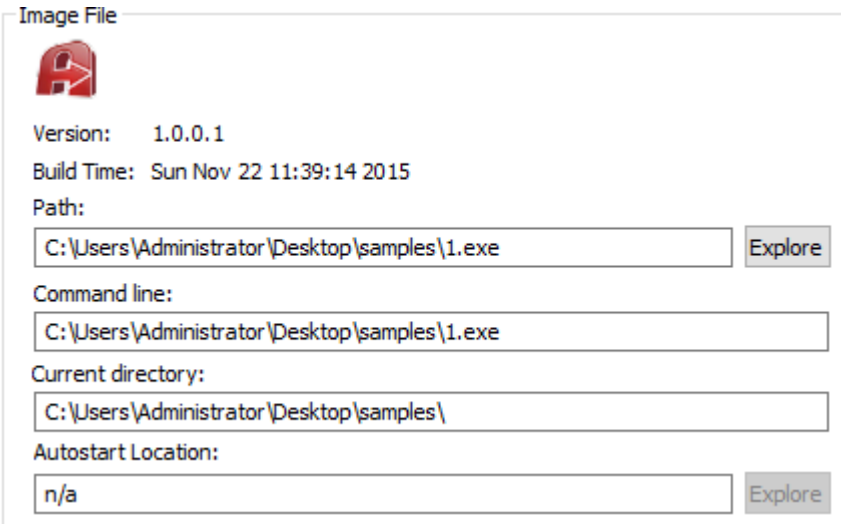
- **Análise:** No painel inferior (*Lower Pane*), aba *Handles*, filtramos pelo tipo "Mutant". Mutexes são usados por malwares para garantir que apenas uma instância da ameaça esteja rodando no sistema.

- **Resposta:**
  `\Sessions\X\BaseNamedObjects\SMX:XXXX:XXX:WilStaging_XX`



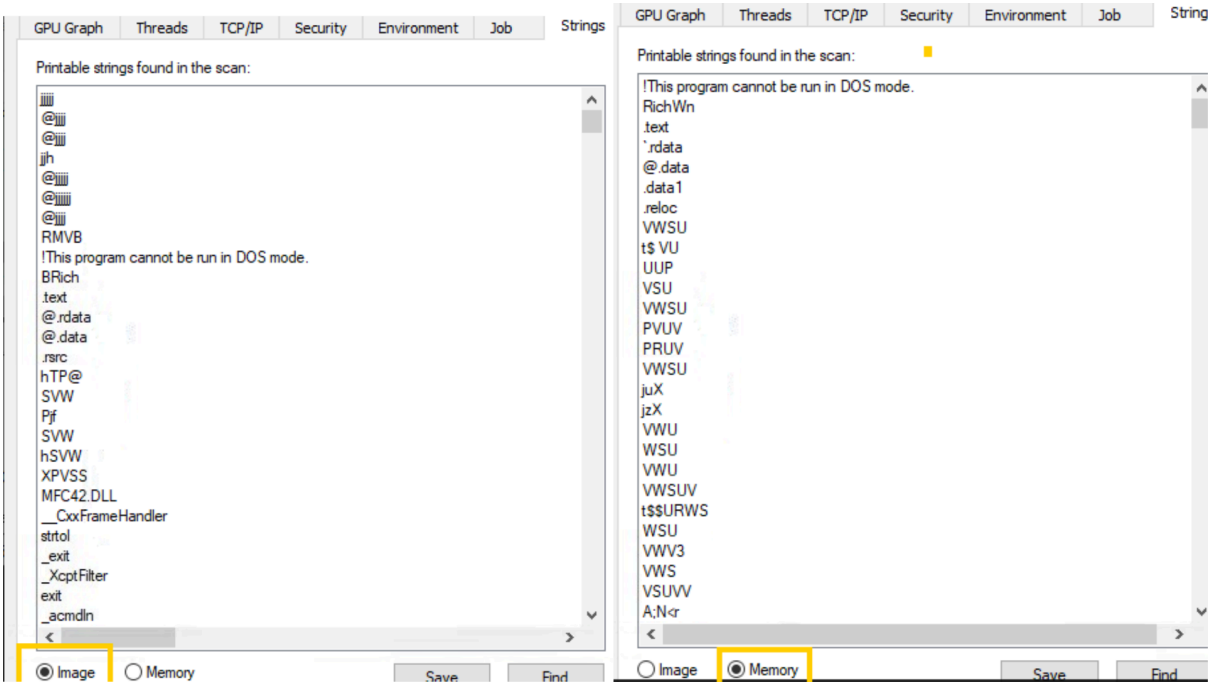
2. O arquivo analisado está assinado por uma organização conhecida?

- **Análise:** Na aba *Image* das Propriedades, o botão *Verify* revelou que, embora o arquivo alegue ser da Microsoft, não há uma assinatura digital válida.
  Resposta: N



3. O processo na memória é o mesmo que o processo no disco (Integridade)?

- **Análise:** Ao comparar as *Strings* das abas *Image* (disco) e *Memory* (RAM), notou-se uma discrepância total, confirmando que o processo sofreu **Process Hollowing**.
- **Resposta:** N



Análise de Persistência e Sistema: Regshot

O **Regshot** é um utilitário de comparação de registros que permite identificar mudanças permanentes feitas pelo malware no Windows. Ao contrário do ProcMon, ele não precisa estar rodando enquanto o malware executa, o que evita técnicas de evasão baseadas em detecção de processos de análise.

1. Funcionamento em 3 Etapas

1. **1st Shot (Primeira Foto):** Captura o estado limpo do Registro do Windows antes da execução.
2. **Execução do Malware:** O artefato é executado e deixado agir por alguns minutos.
3. **2nd Shot (Segunda Foto) + Compare:** Captura o estado pós-infecção e gera um relatório detalhando chaves adicionadas, valores modificados e arquivos alterados.

2. Vantagem Estratégica: Anti-Evasão

Muitos malwares modernos verificam a lista de processos em busca de `procmon.exe` ou `apimonitor.exe` e encerram sua atividade se os encontrarem. Como o Regshot tira "fotos" estáticas e não monitora o comportamento em tempo real, o malware não consegue detectá-lo, permitindo que o analista veja o resultado final da infecção (como a criação de chaves de inicialização automática).

3. Redução de Ruído

Como o Regshot registra **toda** e qualquer mudança no sistema, é vital encerrar o máximo de processos legítimos em segundo plano e não interagir com o Windows durante o teste, para evitar falsos positivos no relatório final.